

Five weaknesses. One clear takeaway.

Testing of a locally hosted OWASP Juice Shop instance identified five security findings across authorization, injection, client-side scripting, and information disclosure, including cross-origin data exposure.

BOUNDARY

Controlled local assessment only

OWASP Juice Shop running on **localhost:3000**; evidence should not be read as a statement about a production system.

CORE TAKEAWAY

Five control layers need attention

Authentication, authorization, input handling and output encoding, web-server exposure controls, plus cross-origin data-sharing controls.

Scope, objectives, and methodology.

A controlled workflow for turning observed behavior into practical remediation.

SCOPE

The local OWASP Juice Shop training instance only (**localhost:3000**), plus a separate local test page on **localhost:3001** used for the cross-origin test in Finding 05.

OBJECTIVES

Understand weaknesses, perform controlled tests, capture evidence, assess impact, and document remediation.

METHODOLOGY

Identify functionality, test locally, observe responses, classify the weakness, assess impact, and record recommendations.

FINDINGS OVERVIEW

- 01 Product tampering · authorization
- 02 SQL injection · authentication
- 03 XSS · client-side execution
- 04 Sensitive data exposure · public files
- 05 Email leak (JSONP) · cross-origin information disclosure

Tools: web browser, Developer Tools, and Postman. Finding 05 used the web browser and a local test page.

Five findings, one compact view.

Each finding is grounded in observed behavior from the local assessment.

ID	FINDING	OBSERVATION	IMPACT
01	Product tampering API authorization	PUT /api/Products/9 changed a product description and returned success.	Unauthorized users could alter application data and product trust.
02	SQL injection Authentication	Crafted SQL input in the email field was accepted without a valid password.	Login controls could be bypassed, exposing protected functionality.
03	Cross-site scripting Client-side injection	A harmless payload in search displayed a JavaScript alert.	Injected scripts could execute in a user's browser.
04	Sensitive data exposure Information disclosure	Public /ftp listing exposed confidential acquisitions.md.	Unauthorized users could access sensitive business information.
05	Email leak / JSONP Cross-origin information disclosure	/rest/user/whoami?callback=test returned user data as JavaScript, readable by a separate local page on localhost:3001.	Sensitive user information, including an email address, can be exposed through an outdated cross-origin mechanism.

Prioritized remediation and conclusion.

1. **Protect authentication first:** eliminate SQL injection paths with parameterized queries or prepared statements, validate inputs, and verify login controls cannot be bypassed.
2. **Enforce authorization:** require authentication and permission checks on product update endpoints; limit changes to appropriately privileged users.
3. **Contain client-side execution:** apply context-appropriate output encoding and safe input handling, with a strong Content Security Policy where appropriate.
4. **Reduce information exposure:** remove sensitive files from web-accessible directories, apply access controls, and disable unnecessary directory listing.
5. **Restrict cross-origin data sharing:** remove JSONP support from sensitive endpoints, use appropriately configured modern cross-origin controls (such as CORS) only where genuinely required, and return only the minimum necessary user information.

Retest each local finding after remediation and retain the before-and-after evidence set.

The assessment demonstrated practical testing against the intentionally vulnerable OWASP Juice Shop, but the evidence is bounded to **localhost:3000** (and the local test page on **localhost:3001**) and is not a statement about a production system.

Email Leak / JSONP.

APPLICATION	CATEGORY
OWASP Juice Shop	Sensitive Data Exposure / Cross-Origin Information Disclosure
TARGET	SEVERITY
Local OWASP Juice Shop (localhost:3000)	Medium
TOOL USED	
Web Browser	

DESCRIPTION

During testing, the user-information endpoint was found to support JSONP through a callback parameter. JSONP is an older cross-origin data-sharing technique that allows data to be returned as executable JavaScript.

TESTING

The following local endpoint was accessed:

```
http://localhost:3000/rest/user/whoami?callback=test
```

The server returned:

```
/**/ typeof test === 'function' && test({
  "user": {
    "id": 1,
    "email": "admin@juice-sh.op",
    "lastLoginIp": "",
    "profileImage": "assets/public/images/uploads/defaultAdmin.png"
  }
});
```

A separate local test page running on http://localhost:3001 loaded the Juice Shop endpoint and successfully displayed the returned user information.

RESULT

User information, including the email address, was successfully received by a separate local page through the JSONP mechanism.

SECURITY IMPACT

Sensitive user information can be exposed through an outdated cross-origin data-sharing mechanism.

SEVERITY REASONING

The demonstrated behavior exposes user information, including an email address. The observed impact is information disclosure rather than modification of application data.

RECOMMENDATION

Remove JSONP support from sensitive endpoints. Use appropriately configured modern cross-origin controls where cross-origin access is genuinely required, and return only the minimum necessary user information.

EVIDENCE · 05-EMAIL-LEAK.PNG

